

Patch Management and System Updates Policy

1. Introduction

The purpose of this Patch Management and System Updates Policy is to ensure all clinic-managed systems remain protected through timely application of security patches and system updates. This policy reduces cybersecurity risk, prevents exploitation of known vulnerabilities, and maintains operational continuity of clinical systems.

2. Scope

This policy applies to workstation computers, laptops, and IT-managed devices operated within the clinic environment. Systems not covered include unmanaged personal devices, third-party medical equipment, and unsupported operating systems.

3. Patch and Update Sources

Patches may originate from operating system vendors, software manufacturers, or managed security providers. Software manufacturers often release cumulative patch bundles and updates on a regular basis, typically monthly.

4. Patch Deployment

Patches will be deployed based on risk level and operational dependency. Automated deployment through Microsoft Intune MDM will be configured to install security and cumulative updates during approved maintenance windows.

5. Maintenance Window

The standard maintenance window for deployment is Monday–Friday between 1:00 AM and 4:00 AM local time to reduce clinical disruption. Reboots may occur during this time. Critical patches may be expedited.

6. Vulnerability Assessment

The clinic will assess vulnerability exposure using vendor advisories, security bulletins, and medical cybersecurity guidance. Where appropriate, penetration testing or external assessments may be conducted.

7. HIPAA Alignment

This patching process aligns with HIPAA Security Rule controls by maintaining system integrity, reducing cyberattack surface, and protecting electronic Protected Health Information (ePHI) processed or stored on clinic-managed systems.

8. Compliance and Reporting

Devices are considered compliant if they meet patch currency requirements, maintain up-to-date malware signatures, and successfully check in to Intune within 24 hours. Non-compliant devices will be flagged and remediated.

9. Exception Management

Exceptions may be granted for legacy clinical systems that cannot be patched due to vendor restrictions or operational constraints. All exceptions must be documented and reviewed quarterly.

Approval Signatures

Prepared By (IT Technician):	_____	Date: _____
Approved By (Clinic Manager):	_____	Date: _____
Approved By (IT Supervisor):	_____	Date: _____